

Website Vulnerability Scanner Report

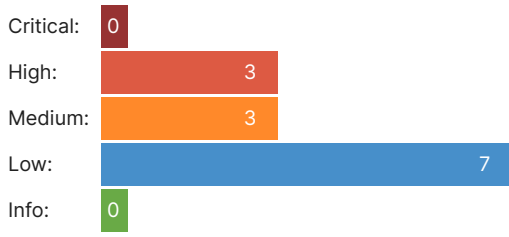
✓ <https://dev-app-brisurf.brins.co.id/login>

Summary

Overall risk level:

High

Risk ratings:



Scan information:

Start time: Aug 05, 2026 / 10:02:11 UTC+07
Finish time: Aug 05, 2026 / 10:06:35 UTC+07
Scan duration: 4 min, 24 sec
Tests performed: 44
VPN Profile: Scan Internal
Scan status: **Finished**

Findings

Vulnerabilities found for php 7.4.30

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-3566	9.8	0.06883	0.93287	A command inject vulnerability allows an attacker to perform command injection on Windows applications that indirectly depend on the CreateProcess function when the specific conditions are satisfied.
CVE-2022-37454	9.8	0.05193	0.91464	The Keccak XKCP SHA-3 reference implementation before fdc6fef has an integer overflow and resultant buffer overflow that allows attackers to execute arbitrary code or eliminate expected cryptographic properties. This occurs in the sponge function interface.
CVE-2022-31630	6.5	0.02197	0.80332	In PHP versions prior to 7.4.33, 8.0.25 and 8.1.12, when using imageloadfont() function in gd extension, it is possible to supply a specially crafted font file, such as if the loaded font is used with imagechar() function, the read outside allocated buffer will be used. This can lead to crashes or disclosure of confidential information.
CVE-2022-31629	6.5	0.49336	0.98748	In PHP versions before 7.4.31, 8.0.24 and 8.1.11, the vulnerability enables network and same-site attackers to set a standard insecure cookie in the victim's browser which is treated as a `__Host-` or `__Secure-` cookie by PHP applications.
CVE-2022-4900	6.2	0.00367	0.28687	A vulnerability was found in PHP where setting the environment variable PHP_CLI_SERVER_WORKERS to a large value leads to a heap buffer overflow.

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.49336

EPSS percentile : 0.98748

CISA KEV: False

CVE : [CVE-2024-3566](#), [CVE-2022-37454](#), [CVE-2022-31630](#), [CVE-2022-31629](#), [CVE-2022-4900](#)

CVSS V3 : 9.8

CWE : [CWE-1035](#)



Vulnerabilities found for nginx 1.18.0

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2021-23017	7.7	0.52838	0.98843	A security issue in nginx resolver was identified, which might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.
CVE-2023-44487	7.5	0.99999	0.99997	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.
CVE-2021-3618	7.4	0.02037	0.78772	ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MiTM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.
CVE-2022-41742	7.1	0.01069	0.60766	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.
CVE-2022-41741	7.0	0.00756	0.50652	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a

				specifically crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.
--	--	--	--	---

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.99999
EPSS percentile : 0.99997
CISA KEV: False
CVE : [CVE-2021-23017](#), [CVE-2023-44487](#), [CVE-2021-3618](#), [CVE-2022-41742](#), [CVE-2022-41741](#)
CVSS V3 : 7.7
CWE : [CWE-1035](#)

 Vulnerabilities found for moment.js 2.20.1
port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2022-31129	7.5	0.04923	0.91069	moment is a JavaScript date library for parsing, validating, manipulating, and formatting dates. Affected versions of moment were found to use an inefficient parsing algorithm. Specifically using string-to-date parsing in moment (more specifically rfc2822 parsing, which is tried by default) has quadratic (N^2) complexity on specific inputs. Users may notice a noticeable slowdown is observed with inputs above 10k characters. Users who pass user-provided strings without sanity length checks to moment constructor are vulnerable to (Re)DoS attacks. The problem is patched in 2.29.4, the patch can be applied to all affected versions with minimal tweaking. Users are advised to upgrade. Users unable to upgrade should consider limiting date lengths accepted from user input.
CVE-2022-24785	7.5	0.05664	0.9204	Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.05664

EPSS percentile : 0.9204

CISA KEV: False

CVE : [CVE-2022-31129](#), [CVE-2022-24785](#)

CVSS V3 : 7.5

CWE : [CWE-1035](#)

Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://dev-app-brisurf.brins.co.id/login	brins_brisurf_ui_session	Set-Cookie: brins_brisurf_ui_session=eyJpdil6lIBvd1BTOUgrK3BsVVIkTUNrVGc0VUE9PSIsInZhbHVlIjoibFRSU3VCWkhNOVUyTUpBUzk3QzA5c1haWC8xeWxkZkNkUmc5Wnh2S3NmYWVWYXNzTEZyRGtWSldLSjMwb0FOR2ZnUkxVbllWUEJmZ0lGMHJ3MINmakFlajlFcGFhSjU0RHoiLCJtYWMiOiI5OTc5ZDc5NzViZGRkNDUyMzg1Y2E3YmExZmFjMTMzNTUwODYwZDgzMDUzMDM0NjgzN2QyZmU3OTM5OGJINGE1liwidGFnljoIn0%3D Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Vulnerabilities found for bootstrap 4.1.3

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-6531	6.4	0.00072	0.22588	A vulnerability has been identified in Bootstrap that exposes users to Cross-Site Scripting (XSS) attacks. The issue is present in the carousel component, where the data-slide and data-slide-to attributes can be exploited through the href attribute of an <a> tag due to inadequate sanitization. This vulnerability could potentially enable attackers to execute arbitrary JavaScript within the victim's browser.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.00072
EPSS percentile : 0.22588
CISA KEV: False
CVE : [CVE-2024-6531](#)
CVSS V3 : 6.4
CWE : [CWE-1035](#)

 Vulnerabilities found for jquery 3.2.1

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2020-11023	6.9	0.8383	0.99657	In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.
CVE-2020-11022	6.9	0.99019	0.99925	In jQuery starting with 1.12.0 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.
CVE-2019-11358	6.1	0.87218	0.99729	jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles jQuery.extend(true, {}, ...) because of Object.prototype pollution. If an unsanitized source object contained an enumerable __proto__ property, it could extend the native Object.prototype.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.99019

EPSS percentile : 0.99925

CISA KEV: False

CVE : [CVE-2020-11023](#), [CVE-2020-11022](#), [CVE-2019-11358](#)

CVSS V3 : 6.9

CWE : [CWE-1035](#)

 Missing security header: X-Content-Type-Options**CONFIRMED**

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

 Details**Risk description:**

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff` .

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Missing security header: Referrer-Policy**CONFIRMED**

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

 Details**Risk description:**

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

▼ Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

```
Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]
```

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Robots.txt file found**CONFIRMED**

port 443/tcp

URL

<https://dev-app-brisurf.brins.co.id/robots.txt>

Risk description:

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

<https://www.theregister.co.uk/2015/05/19/robotstxt/>

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

 Password Submitted in URL**UNCONFIRMED**

port 443/tcp

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/login	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64)	The following form sends inputs of type password plainly in the URL:

		AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	<pre> <form id="frmLogin"> <input type="hidden" name="_token" value="09Ly05uQv4hjiD1ZRSCHHTQDS37weTzKlcpPR8kV"> <div class="login-det"> <div class="form-row"> <label for="">Username</label> <div class="input-group mb-3"> <div class="input-group-prepend"> <i class="far fa-user"></i> </div> <input type="text" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> <div class="form-row"> <label for="">Password</label> <div class="input-group mb-3"> <div class="input-group-prepend"> ... (truncated) Request / Response </div> </div> </div> </div> </form> </pre>
https://dev-app-brisurf.brins.co.id/login	GET	Query: captcha=1d3d2d231d2dd4 password=Secure123456\$ username=1d3d2d231d2dd4 Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36 Cookies: XSRF- TOKEN=eyJpdil6ljJWS1diSnNmTGRIYWg2TXUzbW0rUVE9PSIsInZ...	The following form sends inputs of type password plainly in the URL: <pre> <form id="frmLogin"> <input type="hidden" name="_token" value="vDz4bTIRVy2NxpfmUXvTSWfT15ndugfAIwteCqbm"> <div class="login-det"> <div class="form-row"> <label for="">Username</label> <div class="input-group mb-3"> <div class="input-group-prepend"> <i class="far fa-user"></i> </div> <input type="text" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> </div> </form> </pre>

```
</div>
<div clas
s="form-row">
    <lab
l for="">Password</label>
    <div
class="input-group mb-3">
    <
div class="input-group-prepend">
    <span class="input-group-text" id="basic-
addon1">
    ... (truncated) Reque
st / Response
```

▼ Details

Risk description:

Passwords submitted in URLs have a higher chance of being leaked. The main reason is that URLs can be leaked in browser cross-site requests via the Referer header. Additionally, URLs are usually stored in all kinds of logs. If any access or error logs of the server were publicly accessible, an attacker could also harvest password from it.

Recommendation:

You should submit passwords using POST rather than GET. This way sensitive data won't be shared to other locations via URLs.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-598](#)
OWASP Top 10 - 2021 : [A4 - Insecure Design](#)
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

🚩 Server software and technology found

UNCONFIRMED ⓘ

port 443/tcp

Software / Version	Category
 Bootstrap 4.1.3	UI frameworks
 Highlight.js	JavaScript libraries
 jQuery 3.2.1	JavaScript libraries
 Moment.js 2.20.1	JavaScript libraries
 Nginx 1.18.0	Web servers, Reverse proxies
 OWL Carousel	JavaScript libraries
 PHP 7.4.30	Programming languages
 PHPDebugBar	Development
 Popper	Miscellaneous
 Sectigo	SSL/TLS certificate authorities
 SweetAlert	JavaScript libraries

[▼ Details](#)
Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Login Interface Found

port 443/tcp

CONFIRMED

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	<pre><input type="password" class="form-control" placeholder="Enter Password" aria-label="Use rname" aria-describedby="basic-addon1" name="password"> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Use rname" aria-describedby="basic-addon1" name="password"> <button class="btn btn-sm btn-danger" type="submit" id="btn-login">Login</button></pre> Request / Response

[▼ Details](#)
Risk description:

The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:

Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:

<https://pentest-tools.com/network-vulnerability-scanning/password-auditor>

<http://capec.mitre.org/data/definitions/16.html>

Classification:

CWE : [CWE-287](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)



Security.txt file is missing

CONFIRMED

port 443/tcp

URL
Missing: https://dev-app-brisurf.brins.co.id/.well-known/security.txt

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



HTTP OPTIONS enabled

CONFIRMED

port 443/tcp

URL	Method	Summary
https://dev-app-brisurf.brins.co.id/login	OPTIONS	We did a HTTP OPTIONS request. The server responded with a 200 status code and the header: Allow: GET, HEAD Request / Response

▼ Details

Risk description:

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>
<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (44)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for login interfaces
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit

- ✔ Scanned for PEM-encoded private key material
- ✔ Scanned for partial PEM-encoded private key material

Scan parameters

target: https://dev-app-brisurf.brins.co.id/login
scan_type: Light
authentication: False

Scan stats

Unique Injection Points Detected: 2
URLs spidered: 2
Total number of HTTP requests: 11
Average time until a response was received: 1663ms
